IT & INFORMATION SECURITY POLICY

IT Operations | Policy ID: IT-SEC-001 | Version 1.0 | Effective date: 1 January 2026

Purpose. This fictional policy sets minimum security expectations for protecting company accounts, devices, information and systems. It applies to employees and approved contractors who access company information.

1. Security principles and scope

Company information must be accessed only for legitimate work purposes and handled according to its sensitivity. Employees are responsible for protecting their accounts and devices, even when working remotely or travelling. Report suspected security incidents promptly; do not investigate beyond what is necessary to keep systems safe.

2. Passwords and authentication

Use a unique password or passphrase for each work account. Passwords must be at least 14 characters where the service supports it and should not contain easily guessed personal information. Never share passwords, one-time passcodes, recovery codes or authentication approval requests with another person.

Multi-factor authentication (MFA) must be enabled wherever the company provides it. Use the company-approved password manager to store credentials. If you suspect a password has been exposed, change it immediately from a trusted device and report the concern to IT.

3. Company laptop and device use

Use company-managed devices for company work whenever provided. Keep operating systems, browsers and security software up to date; allow automatic updates to complete. Lock the screen whenever you step away, and do not leave a laptop unattended in a public place or visible in a vehicle.

Do not disable endpoint protection, bypass device controls, install unapproved software or lend a company device to family members or other unauthorised people. Store work files in approved company storage, not personal email, personal cloud drives or removable media unless IT has explicitly approved the method.

4. Public Wi-Fi and remote work

Avoid connecting a work laptop to open or untrusted public Wi-Fi networks. Use a trusted mobile hotspot or another approved secure connection whenever possible. If public Wi-Fi is unavoidable, connect only after enabling the company-approved VPN, verify the network name with the venue, and avoid accessing sensitive systems or transferring confidential files. Never ignore browser certificate or security warnings.

5. Data handling and sharing

Share company information only with people who are authorised to receive it and only through approved company tools. Check recipients and access permissions before sending links or attachments. Use the approved encrypted sharing method for confidential information. Do not upload company data to public AI tools, personal file-sharing services or unapproved applications.

Keep confidential information out of public spaces and conversations. Collect only the information needed for your task. Follow retention and deletion instructions from the relevant system owner; do not delete records subject to a legal hold or investigation.

6. Email, links and phishing

Treat unexpected attachments, urgent payment requests, password-reset messages and unfamiliar links with caution. Check the sender's full address and the destination of a link before opening it. Do not enable macros or install software at the request of an unsolicited message.

If you click a suspicious link, enter credentials on a suspicious page or open an unexpected attachment, stop interacting with it and report it to IT immediately. If you entered your password, change it from a trusted device and tell IT that credentials may be compromised. Do not delete the message; preserve it for investigation.

7. Security incident reporting

Report a lost or stolen device, suspected malware, accidental disclosure, suspicious login, phishing interaction or misdirected email to the IT help channel **within one hour of discovery where practicable**. If the help channel is unavailable, contact your manager and the IT duty contact by the fastest available method.

Include what happened, when it happened, the device or account involved, and any steps already taken. Do not forward suspicious files to colleagues or attempt to clean an infected device unless IT instructs you to do so.

8. Physical security and travel

Keep access cards and devices secure. Do not allow unknown visitors to follow you into restricted work areas. When travelling, keep devices with you where possible, use a privacy screen in crowded places, and avoid discussing confidential work where others can overhear.

9. Access control and acceptable use

Access is granted according to job responsibilities. Do not use another person's account or attempt to access systems or files outside your permission. Notify your manager and IT when a role changes or access is no longer needed. Company systems must not be used to store, view or distribute unlawful, harassing or otherwise prohibited material.

10. Compliance and questions

IT may review security logs and device status for legitimate security and operational purposes, subject to applicable law and company procedures. Employees must cooperate with reasonable security requests and complete required awareness training.

For help, report concerns through the IT help channel. In an urgent incident, use the IT duty contact. This document is a fictional sample policy for the AI Engineering case study; it is not an operational security standard.

Document control: Owner — IT Operations | Review cycle — annually | Version 1.0